

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 09 月 25 日

第 1 頁，共 10 頁

單選題 50 題 (佔 100%)

C	1. 如附圖所示，關於封包過濾防火牆規則，下列敘述何者不正確？ <table><tr><th></th><th>來源位址</th><th>目的位址</th><th>協定</th><th>來源埠</th><th>目的埠</th><th>Action</th></tr><tr><td>#1</td><td>10.0.0.1</td><td>10.0.0.2</td><td>TCP</td><td>0-65535</td><td>80</td><td>Allow</td></tr><tr><td>#2</td><td>10.0.0.1</td><td>10.0.0.2</td><td>TCP</td><td>0-65535</td><td>443</td><td>Allow</td></tr><tr><td>#3</td><td>10.0.0.1</td><td>10.0.0.2</td><td>UDP</td><td>0-65535</td><td>53</td><td>Allow</td></tr><tr><td>#4</td><td>10.0.0.2</td><td>10.0.0.1</td><td>TCP</td><td>0-65535</td><td>443</td><td>Allow</td></tr><tr><td>#5</td><td>0.0.0.0/0</td><td>0.0.0.0/0</td><td>ALL</td><td>0-65535</td><td>0-65535</td><td>Deny</td></tr></table> (A) 10.0.0.1 可以通往 10.0.0.2 的 80 埠 (B) 10.0.0.1 可以通往 10.0.0.2 的 443 埠 (C) 10.0.0.2 可以通往 10.0.0.1 的 80 埠 (D) 10.0.0.2 可以通往 10.0.0.1 的 443 埠		來源位址	目的位址	協定	來源埠	目的埠	Action	#1	10.0.0.1	10.0.0.2	TCP	0-65535	80	Allow	#2	10.0.0.1	10.0.0.2	TCP	0-65535	443	Allow	#3	10.0.0.1	10.0.0.2	UDP	0-65535	53	Allow	#4	10.0.0.2	10.0.0.1	TCP	0-65535	443	Allow	#5	0.0.0.0/0	0.0.0.0/0	ALL	0-65535	0-65535	Deny
	來源位址	目的位址	協定	來源埠	目的埠	Action																																					
#1	10.0.0.1	10.0.0.2	TCP	0-65535	80	Allow																																					
#2	10.0.0.1	10.0.0.2	TCP	0-65535	443	Allow																																					
#3	10.0.0.1	10.0.0.2	UDP	0-65535	53	Allow																																					
#4	10.0.0.2	10.0.0.1	TCP	0-65535	443	Allow																																					
#5	0.0.0.0/0	0.0.0.0/0	ALL	0-65535	0-65535	Deny																																					
B	2. 下列何者是網路紀錄（Cookies）常被駭客利用來進行攻擊的主要原因？ (A) 它是一種有漏洞的網路協定（Protocol） (B) 它可能儲存了使用者瀏覽網頁的資訊、帳號與密碼 (C) 它是會變種的電腦病毒 (D) 它是一種容易學習的攻擊程式																																										
C	3. 關於網路位址轉換（Network Address Translation, NAT），下列敘述何者「不」正確？ (A) 可減少公有 IP（Public IP）位址使用數量 (B) 可隱藏內部 IP 位址 (C) 可防止暴力攻擊（Brute-Force Attack） (D) 可在內部網路中使用私有 IP 位址（Private IP）																																										
D	4. 下列何者是私有 IP 位址（Private IP）？ (A) 7.7.7.7 (B) 8.8.8.8 (C) 9.9.9.9 (D) 10.10.10.10																																										
D	5. 下列何者是微軟網路芳鄰常見使用 Port？ (A) 110 (B) 133 (C) 153 (D) 137																																										
C	6. 關於防火牆規則管理，下列敘述何者「不」正確？ (A) 安全性規則的數量會影響防火牆的效能																																										

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 09 月 25 日

第 2 頁，共 10 頁

	(B) 防火牆管理員應制定一套規則制定標準讓大家遵從，以避免每個人的管理模式不同，導致防火牆規則難管理 (C) 防火牆設定無需訂定管理辦法，只要管理員熟悉設備即可 (D) 防火牆開放方式應使用白名單（Whitelist）開放，較黑名單（Blacklist）安全
A	7. 關於狀態檢視防火牆（Stateful Inspection Firewall），下列敘述何者「不」正確？ (A) 所檢查的內容較封包過濾防火牆少 (B) 可以根據目的埠號做阻擋 (C) 可以根據目的位址做阻擋 (D) 會紀錄連線狀態
D	8. 關於代理防火牆（Proxy），下列敘述何者「不」正確？ (A) 使用者透過代理防火牆進入（Inbound）時，代理防火牆會開啟新連線，再將回覆回給使用者 (B) 駭客可能透過多層代理防火牆來隱匿其真實來源位址 (C) 代理防火牆設定上較複雜，需依照各種協定客製代理程式 (D) 代理防火牆運作於第四層網路層
D	9. 下列何種應用服務會使用到傳輸控制協定（Transmission Control Protocol, TCP）和使用者資料報協定（User Datagram Protocol, UDP）兩種傳輸層協定？ (A) FTP (B) SMTP (C) Telnet (D) DNS
B	10. 交換器在下列何種情況會將一個訊框（Frame）溢送（Flood）到所有交換器的端口？ (A) 當來源的 MAC 位址並未在交換器的 MAC 位址表格內 (B) 當目的的 MAC 位址並未在交換器的 MAC 位址表格內 (C) 當目的的 MAC 位址是多點傳送（Multicast）位址 (D) 當目的的 MAC 位址是 00-00-00-00-00-00
A	11. 虛擬私有網路（Virtual Private Network, VPN）是利用下列何種技術來建立安全通訊連線？ (A) 通道（Tunnel）技術 (B) 資料壓縮技術 (C) 調變與解調變技術 (D) 無線通訊技術

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 09 月 25 日

第 3 頁，共 10 頁

B	12. 在 App 設計中，常透過 Web Service 做資料交換，且須考量資訊安全議題，下列敘述何者「不」正確？ (A) 使用 HTTPS 取代 HTTP 通訊協定 (B) 傳遞資料使用 GET 方法較 POST 方法安全 (C) 傳遞資料時，資料應加密 (D) 為使傳遞資料更安全，App 原始碼中 Web Service 的 URL 也應加密
D	13. 關於傳輸控制協定 (Transmission Control Protocol, TCP) 連接狀態，下列敘述何者「不」正確？ (A) SYN-SENT：Client 送往 Server 的第一個要求連線封包 (已送出 SYN，在等待對方回覆的期間) (B) SYN-RECEIVED：Server 收到 Client 的連線後，回覆給 Client SYN+ACK，並且等待 Client 回覆 ACK (C) ESTABLISHED：Client 回覆 ACK 後，Client 及 Server 均進入 Established 狀態，雙方可以正常傳輸，TCP 三向交握 (Three-way Handshake) 已完成 (D) CLOSE-WAIT：被動關閉方收到 FIN 後發出 SYN+ACK 時，會進入這個狀態，此時可以傳輸資料，也可以接收資料
C	14. 下列敘述何者「不」正確？ (A) 木馬後門程式常偽裝成提供便利或實用的免費軟體，吸引使用者下載使用 (B) 電腦病毒具有散播、隱藏、感染、潛伏及破壞等特性 (C) 阻斷服務攻擊 (Denial of Service Attack, DoS) 通常指攻擊者攔截通訊的資料，並讓資料最後傳送到錯誤的接收者 (D) 蠕蟲 (Worm) 會不斷複製，並利用網路感染其他主機
D	15. 下列何者「不」是整合式威脅管理 (Unified Threat Management, UTM) 設備的常見功能？ (A) 啟用入侵防禦系統 (Intrusion Prevention System, IPS)，防禦異常的網路攻擊封包 (B) 管理外網與內網的各子網段交換路由 (C) 以 IPSec 通訊協定建立加密傳輸路由 (D) 使用 Honeypot 誘捕系統功能來蒐集與分析入侵威脅
D	16. 您目前負責管理一個高度敏感性的實驗室網路，為了方便偵測與監控實驗室的網路事件，故透過傳統的 Syslog 將重要的設備 (如防火牆、路由器) 產生的事件記錄傳送並集中存放在一部 Syslog 伺服器上，但公司的資安顧問認為傳統的 Syslog 使 UDP 協定無法確保其穩定性，另一方面，Syslog 採明文傳送且未提供驗證能力，易遭受竊聽與連線

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 09 月 25 日

第 4 頁，共 10 頁

	攔截攻擊，若要解決上述顧問所質疑的 Syslog 相關問題，下列何者「不」是較有效的解決方案？ (A) 採用 TCP 為基礎的 Syslog 伺服器 (B) 在設備與 Syslog 伺服器間建立 TLS/SSL 安全性連線 (C) 在設備與 Syslog 伺服器間建立 IPSec 安全性連線 (D) 安裝入侵防禦系統抵擋上述所有的攻擊
C	17. 下列何者「不」屬於預防性（Preventive）的安全管控機制？ (A) 實施強制性密碼原則管理 (B) 安裝防毒軟體並啟動即時偵測 (C) 定期檢視安全記錄檔（Log） (D) 定期套用安全性更新（Patch）
A	18. 若要安全傳送資料，達到只有接收方能開啟並確認內容未遭篡改，下列敘述何者正確？ (A) 資料以雜湊（Hash）演算後，以接收方的公開金鑰（Public Key）加密後傳送 (B) 資料以雜湊（Hash）演算後，以傳送者的公開金鑰（Public Key）加密後傳送 (C) 資料以雜湊（Hash）演算後，以接收方的私密金鑰（Private Key）加密後傳送 (D) 資料以雜湊（Hash）演算後，以傳送者的私密金鑰（Private Key）加密後傳送
B	19. 下列何者可在附圖程式碼中達成 SQL Injection 攻擊？ <pre>String query = "SELECT * FROM UserData WHERE uID='" + request.getParameter("id") + "'";</pre> (A) id = 1 or 1 (B) ' or '1'=1 (C) uID = 1 or 1 (D) '1'=1 or 1'
C	20. 若在伺服器的紀錄檔中，發現附圖一連串大量的記錄內容，最可能發生了下列何種類型的攻擊？ <pre>Aug 12 11:39:12 ip-10-1-2-2 sshd[28392]: Invalid user admin from remotehost passwd=passwd Aug 12 11:39:26 ip-10-1-2-2 sshd[28398]: Invalid user admin from remotehost passwd=admin Aug 12 11:39:29 ip-10-1-2-2 sshd[28400]: Invalid user admin from remotehost passwd=root Aug 12 11:39:38 ip-10-1-2-2 sshd[28406]: Invalid user admin from</pre>

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 09 月 25 日

第 5 頁，共 10 頁

	remotehost passwd=1qaz2wsx Aug 12 20:40:57 ip-10-1-2-254 sshd[29520]: Invalid user admin from remotehost passwd=qwertasdfg (A) 中間人攻擊 (Man-In-The-Middle Attack) (B) 暴力攻擊法 (Brute-Force Attack) (C) 字典攻擊法 (Dictionary Attack) (D) 彩虹表攻擊 (Rainbow Table Attack)
B	21. 關於 IP 位址欺騙 (IP address spoofing)，下列敘述何者較正確？ (A) 利用資料庫弱點冒用他人 IP (B) 透過變造封包等手法，以偽冒他人的 IP (C) 不會因為 IP 重複導致系統錯誤 (D) 利用 IP 清單避免使用者遭受攻擊
A	22. 關於 SYN 洪水攻擊 (SYN Flood)，下列敘述何者較正確？ (A) 大量送出 SYN 封包至目標 (B) 收到 SYN 封包後不回應 (C) 由於目標持續等待 SYN 封包導致資源耗盡 (D) 在 SYN 封包中帶入惡意指令進行攻擊
A	23. 關於提權 (Privilege Escalation)，下列敘述何者正確？ (A) 提升使用者權限至系統管理權限 (B) 刪除入侵軌跡 (C) 刪除使用者帳號 (D) 找出具有最高權限的帳號
C	24. 關於黑箱測試 (Black-Box Testing)，下列敘述何者正確？ (A) 更容易鑑別出軟體問題的根因 (B) 更容易發現邏輯性缺失 (C) 更容易鑑別出軟體部署後的問題 (D) 可測試程式碼涵蓋範圍更大
B	25. 全自動區分電腦和人類的公開圖靈測試 (Completely Automated Public Turing test to tell Computers and Humans Apart, CAPTCHA)，較能防護下列何種攻擊？ (A) 資料隱碼攻擊 (SQL Injection) (B) 跨網站偽造請求 (Cross-Site Request Forgery, CSRF) (C) 跨站指令碼攻擊 (Cross-Site Scripting, XSS) (D) 緩衝區溢位 (Buffer Overflow)
B	26. 關於入侵偵測系統 (Intrusion Detection System, IDS)，下列敘述何者「不」正確？

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 09 月 25 日

第 6 頁，共 10 頁

	(A) 扮演良好的偵測角色 (B) 為組織內關鍵阻擋之設備 (C) 正確的運用可掌握組織內目前資安樣態 (D) 透過邊界路由以偵測模式 (Sniffer Mode) 部署並觀察全域流量為最佳部署方式
D	27. 某網站在設計時進行過安全分析，也在開發時要求程序員編寫安全的代碼，但佈署時由於管理員將備份存放在 WEB 目錄下導致了攻擊者可直接下載備份，為了發現系統中是否存在其他類似問題，下列何種測試方式是最佳的測試方法？ (A) 模糊測試 (B) 源碼測試 (C) 整合測試 (D) 滲透測試
D	28. 系統人員通常無法立刻針對漏洞本身進行修補 (Patch) 的是下列何種漏洞？ (A) 區域漏洞 (Local Vulnerabilities) (B) 稀疏漏洞 (Sparse Vulnerabilities) (C) 沙盒漏洞 (Sandbox Vulnerabilities) (D) 零時差漏洞 (Zero-Day Vulnerabilities)
A	29. 下列何者「不」是進行中間人攻擊 (Man-In-The-Middle Attack, MITM) 所採用的技巧？ (A) Clickjacking (B) Sniffing (C) Packet Injecting (D) Session Hijacking
C	30. 關於弱點評估，下列敘述何者正確？ (A) 不同的弱點管理方式都可使用相同的風險評級對弱點進行評分 (B) 具高風險弱點可協助組織提升在業界中的口碑 (C) 弱掃報告中的弱點評分可依據組織產業類型或性質重新給予評分 (D) 弱掃工具提供的報告結果準確性高，無需再對弱點進行評估
D	31. 關於連線劫持 (Session Hijacking) 的偵測與防禦，下列敘述何者「不」正確？ (A) 實踐自動登出的功能也是連線劫持的其中一種防禦方式 (B) 防毒軟體對連線劫持也有部分功效 (C) 加密的連線可預防連線劫持 (D) IDS 可偵測與防禦連線劫持

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 09 月 25 日

第 7 頁，共 10 頁

C	32. 關於資料備份，下列敘述何者正確？ (A) 為避免備份資料佔用儲存空間，僅需留存最新副本即可 (B) 資料庫叢集之抄寫功能 (Replication)，即為資料備份機制 (C) 備份資料還原測試應定期執行，確保副本資料正常留存 (D) 資料中心 (IDC) 進出管制嚴密，因此備份資料與來源資料存放於同地機房即可避免損毀
A	33. 關於去識別化 (De-identification)，是為了保護資料的何種特性？ (A) 機密性 (Confidentiality) (B) 完整性 (Integrity) (C) 可用性 (Availability) (D) 可歸責性 (Accountability)
B	34. 某組織規劃的資料備份策略為週日進行完全備份，週一至週六進行「X」備份。若組織在週四因系統問題導致資料毀損，此時資料備份管理員之處理程序為先還原週日完全備份資料後，再依序將週一至週三所備份之資料還原，請問此「X」備份是指下列何者？ (A) 完整備份 (Full Backup) (B) 增量備份 (Incremental Backup) (C) 減量備份 (Decremental Backup) (D) 差異備份 (Differential Backup)
B	35. 在雜湊 (Hash) 之前將內容插入特定字串，稱為下列何者？ (A) 數位簽章 (Digital Signature) (B) 加鹽 (Salt) (C) 編碼 (Encoding) (D) 替換 (Substitution)
D	36. 某公司將網站伺服器內的五顆硬碟作 RAID 5，並且規劃備份機制為每週日 23:30 進行完整備份 (Full Backup)，其餘每天 23:30 進行差異備份 (Differential Backup)，若於某週三 23:00 時伺服器其中一顆硬碟發生故障，此時應採取下列何種處理方式？ (A) 將上週五的 Full Backup 磁帶回存，再依序將週日、一、二的增量備份磁帶回存 (B) 將上週五的 Full Backup 磁帶回存，再將週二的備份磁帶回存 (C) 將上週三的磁帶回存 (D) 只需更換有問題的硬碟，重作 Rebuild 即可
C	37. 關於 Syslog 日誌傳輸協議，下列敘述何者正確？ (A) 為確保資料傳輸效率，僅能透過 UDP 協議使用 (B) 為確保資料正確性，僅能透過 TCP 協議使用 (C) 為確保資料機密性，可透過 TLS 協議進行加密傳輸

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 09 月 25 日

第 8 頁，共 10 頁

	(D) 為確保資料機密性，日誌需先自行加密後再進行傳輸
D	38. 在進行日誌分析前，通常會先將蒐集的資料中，格式不正確或完整度不足的資料進行刪除或修正，此舉稱為下列何者？ (A) Data Collection (B) Data Profiling (C) Data Normalization (D) Data Cleaning
D	39. 若日誌與系統管理人員，想把不同系統、程式之日誌檔進行管理、分析，應先將這些日誌檔如何處理較合適？ (A) 去識別化 (B) 文件化 (C) 無需處理 (D) 正規化
B	40. 若在系統的日誌中看到附圖記錄，最可能為下列何種攻擊手法？ http://www.CCCompany.com/GET/process.php/../../../../../../../../etc/passwd (A) 文件注入 (Content Injection) (B) 目錄遊走 (Directory Traversal) (C) SQL 注入 (SQL Injection) (D) 跨站指令碼攻擊 (Cross-Site Scripting, XSS)
B	41. 關於日誌與監控作業，下列敘述何者較「不」正確？ (A) 日誌應記錄使用者活動、異常，並且依法定要求的時間保存 (B) 系統日誌為避免外洩，應在出資安事件時才查詢，平日不應存取 (C) 日誌應避免可被該系統管理人員修改 (D) 資訊處理系統、網路設備的鐘訊，應與議定的準確時間來源同步
D	42. 下列何種雲端型態的安全性最佳？ (A) 公有雲 (B) 社區雲 (C) 混合雲 (D) 私有雲
A	43. 下列何者「不」是和雲端安全有關的國際標準？ (A) ISO/IEC :27011 (B) ISO/IEC :27017 (C) ISO/IEC :27018 (D) CSA STAR
C	44. 若連線到使用雲端架設的 HTTP 服務時，回傳 404 的 HTTP 狀態碼，下列敘述何者正確？

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 09 月 25 日

第 9 頁，共 10 頁

	(A) 代表 Gateway Timeout，伺服器嘗試執行請求時，未能及時從其他伺服器取得回應 (B) 代表 OK，請求已成功，所請求的回應標頭或資料本體將被送回 (C) 代表 Not Found，請求失敗，請求所希望得到的資源未在伺服器上被發現 (D) 代表 Request Timeout，請求逾時，客戶端沒有在伺服器預備等待的時間內完成一個請求的傳送
D	45. 有些行動應用程式 (App) 會要求授權讀取行動裝置上的個人資訊，如：聯絡人資料、照片與撥打電話、簡訊等，下列敘述何者「不」正確？ (A) 授權 App 直接用行動裝置撥打電話或簡訊給特定對象可能會需要額外費用 (B) 行動裝置上的聯絡人資料、照片屬於個人資料，要小心保護，以免觸犯「個人資料保護法」 (C) 絕不散佈未經求證之訊息、及違反社會善良風俗之照片或影片，以免觸法 (D) 應授權所有 App 對於行動裝置上聯絡人的讀取權限
A	46. 下列何者較「不」能避免使用者，在使用行動裝置時，遭受網路釣魚攻擊 (Phishing) ？ (A) 用無痕跡的瀏覽器開啟網頁 (B) 留意點選的網址是否異常 (C) 不隨意開啟來路不明的信件連結 (D) 不隨意連接不信任的 Wi-Fi 熱點
A	47. 關於運用主機卡模擬 (Host Card Emulation, HCE) 於行動裝置上進行行動支付，下列敘述哪些是正確的？(1)從雲端支付平台取得的金鑰是有時效性的、(2)無需挑選通過服務平台安全認證的手機、(3)手機無需具備安全元件來儲存支付資訊、(4)需更換具備安全防護特殊的 SIM 卡才能支援 (A) (1)(2)(3) (B) (1)(2)(4) (C) (1)(3)(4) (D) (2)(3)(4)
B	48. 物聯網裝置採用低功耗藍牙通訊技術建立連線時，選用頻外配對 (Out-Of-Band, OOB) 是為了可以避免下列何種惡意攻擊？ (A) 緩衝區溢位 (Buffer Overflow) (B) 中間人攻擊 (Man-in-the-Middle Attack) (C) 重送攻擊 (Replay Attack)

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 09 月 25 日

第 10 頁，共 10 頁

	(D) 蟲洞攻擊 (Wormhole Attack)
C	49. 當兩個物聯網裝置在通訊過程中，攻擊者分別對個別裝置進行獨立連線，並擷取與轉送雙方間傳遞資料，使原通訊雙方以為處於一個安全的資料傳輸環境，此狀況屬於下列何種攻擊手法？ (A) 重送攻擊 (Replay Attack) (B) 分割重組攻擊 (Teardrop Attack) (C) 中間人攻擊 (Man-In-The-Middle Attack, MITM) (D) 路由迴圈攻擊 (Loop Routing Attack)
A	50. 惡意駭客可以架設高功率的無線基地台，冒用相同的 SSID 名稱，來誘導使用者連線至偽冒的基地台，偷取使用者的登入帳號及密碼。下列何者為上述的攻擊方式？ (A) Rouge AP and Evil twin (B) Sniffing (C) MAC Address Spoofing (D) Man in the Middle Attack